

Exercice : Sécurisation réseau TPE (Techno Vert)

Maël - BTS SIO

5 décembre 2025

1 Analyse du réseau actuel

1.1 Identification des risques et failles

Voici 5 failles majeures identifiées dans l'infrastructure actuelle :

1. **Absence de segmentation (Réseau plat)** : Tous les PC et le NAS sont sur le même réseau. Si un poste est infecté, le virus peut attaquer directement le NAS et les autres PC.
2. **Usage dangereux du Wi-Fi** : L'utilisation du réseau "Invité" pour le travail interne expose les données de l'entreprise à n'importe quel visiteur connecté.
3. **Matériel inadapté** : Le switch non-manageable empêche la création de VLANs pour séparer les flux.
4. **Données exposées** : Le NAS contenant les données sensibles est accessible sans filtrage réseau spécifique.
5. **Absence de visibilité** : Il n'y a aucune supervision pour détecter une attaque ou une panne en temps réel.

1.2 Limites de la Box Internet

Une box grand public est insuffisante pour une entreprise de 20 personnes car :

- Elle ne permet pas de créer des règles de pare-feu fines (filtrage par IP, port, protocole) entre différents zones locales.
- Elle ne gère pas (ou très mal) les VLANs nécessaires à la sécurité.
- Ses capacités de journalisation (logs) sont inexistantes, empêchant l'analyse post-incident.

2 Conception d'une architecture sécurisée

2.1 Schéma réseau logique proposé

Équipements requis :

- 1 Pare-feu/Routeur professionnel (ex : Fortinet, Stormshield, pfSense).
- 1 Switch Manageable (Niveau 2/3).
- Points d'accès Wi-Fi professionnels (compatibles VLAN).

Architecture des zones (VLANs) :

- **VLAN 10 - Administration** : Postes de direction et comptabilité (Données critiques).
- **VLAN 20 - Employés** : Postes de travail standards.
- **VLAN 30 - Serveurs/NAS** : Zone isolée, accessible uniquement via des ports spécifiques (ex : SMB, HTTPS) depuis les VLAN 10 et 20.
- **VLAN 90 - Invités (Wi-Fi)** : Accès Internet uniquement, isolation totale du réseau interne.

2.2 Justification de la segmentation

La segmentation réseau est essentielle pour **limiter la surface d'attaque**. En séparant les services :

- On empêche la propagation latérale d'un virus (si un PC employé est infecté, le NAS et la Compta restent protégés par le pare-feu).
- On optimise les performances en réduisant le domaine de diffusion (broadcast).

3 Mesures de sécurité à mettre en place

Voici 6 mesures prioritaires pour sécuriser Techno Vert :

1. **Mise en place de VLANs** : Pour séparer physiquement et logiquement les flux de données (Invités vs Production).
2. **Filtrage strict (Pare-feu)** : Bloquer tout trafic entrant non sollicité et limiter le trafic sortant au strict nécessaire (bloquer les sites malveillants).
3. **Sécurisation du Wi-Fi (WPA3)** : Utiliser le protocole WPA3-Enterprise si possible, ou à minima WPA2/3 avec un mot de passe complexe, sur un SSID séparé du réseau invité.
4. **Sauvegardes hors ligne** : Configurer une sauvegarde du NAS sur un support déconnecté (disque USB ou Cloud immuable) pour contrer les ransomwares.
5. **Mise à jour des firmwares** : Maintenir à jour le routeur, le switch et le NAS pour combler les failles de sécurité connues.
6. **VPN pour l'accès distant** : Remplacer tout accès direct (port forwarding) par un VPN sécurisé pour les employés en télétravail.

4 Plan d'action

Priorité 1 : Immédiat (Urgence)

- Interdire l'usage du Wi-Fi "Invité" pour l'accès aux données internes.
- Changer les mots de passe par défaut de tous les équipements (Box, NAS).
- Vérifier que le NAS a une sauvegarde fonctionnelle.

Priorité 2 : Court terme (Investissement)

- Acquérir et installer un Pare-feu et un Switch manageable.
- Configurer les VLANs et migrer les postes informatiques.
- Mettre en place les règles de filtrage inter-VLAN.

Priorité 3 : Moyen terme (Amélioration)

- Mettre en place un outil de supervision (monitoring) pour alerter en cas de panne.
- Former les employés aux bonnes pratiques (ne pas se connecter au Wi-Fi invité).